



Finance and Insurance **Threat Landscape** Report

Reporting Period: January 1 to March 31, 2026

Ransomware & Data-Leak Sites

Ransomware remains a top cyber threat to all organizations globally. This section showcases the top ransomware groups targeting the finance and insurance sector and what you can do about them.

145

ransomware attacks

▲ 44%

since last reporting period
(October 1 to December 31, 2025)

Key Points and Recommendations

- Finance and insurance victims posted to data-leak sites rose sharply period over period, with postings spread across considerably more groups, indicating broader opportunistic exposure rather than a surge by any single operator.
- "Clop" and "DragonForce" posted disproportionately more finance and insurance targets than their all-sector averages would predict, suggesting deliberate sector focus; meanwhile, "Qilin" remained persistent but declined substantially and its sector activity now tracks closer to its all-sector average.
- "The Gentlemen" and "ShinyHunters" appeared only in the latest reporting period at volumes well above their all-sector averages. Meanwhile, previously active groups including "Akira" and "KillSec" saw reduced sector postings, reflecting meaningful group churn across periods.
- Prioritize patching MOVEit-class managed-file-transfer vulnerabilities exploited by Clop; enforce phishing-resistant MFA on all VPN and remote-access tool gateways; deploy EDR policies blocking Living-off-the-Land (LotL) binaries such as certutil and wmic to counter DragonForce affiliate tradecraft.

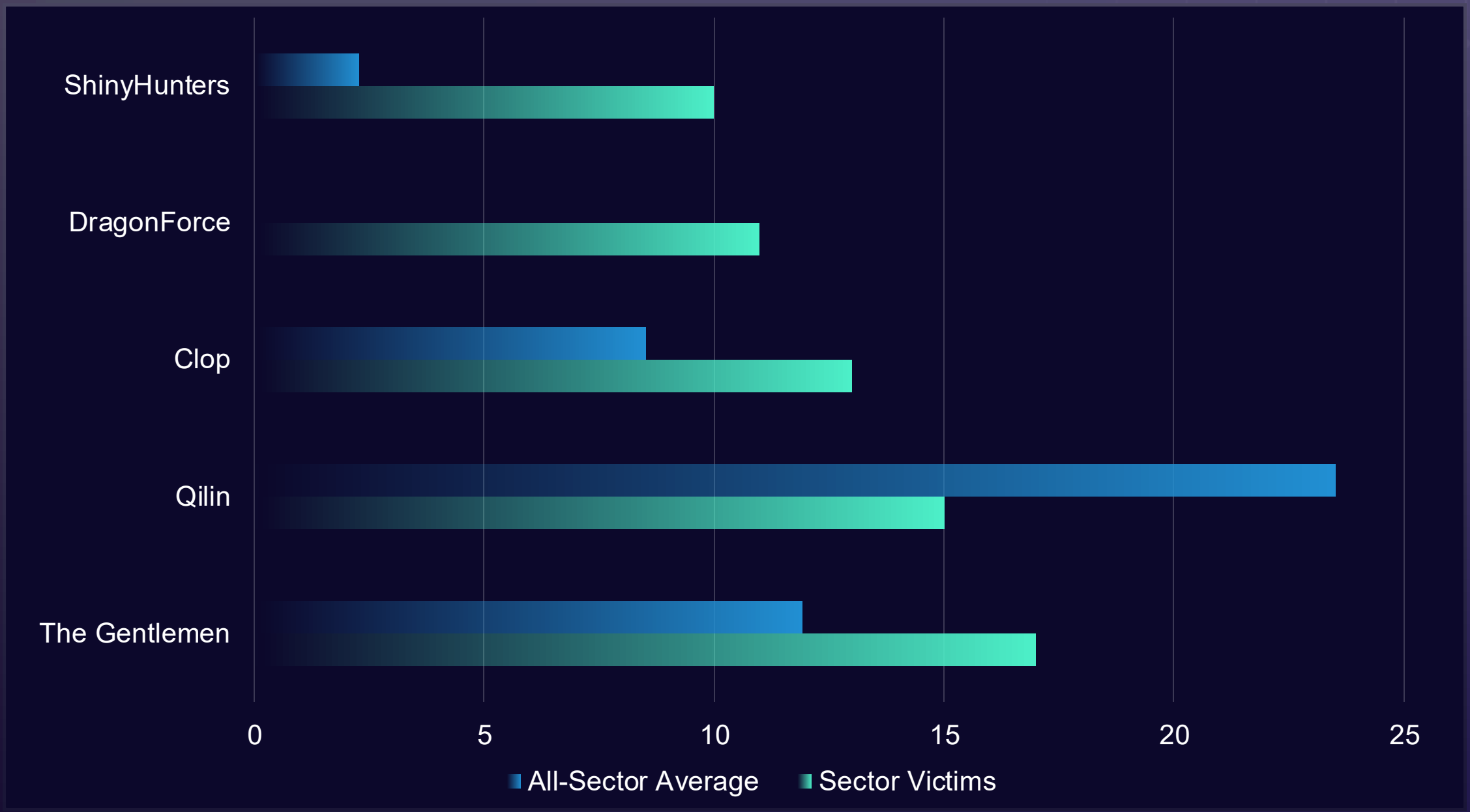


Figure 1: Number of finance and insurance organizations named on data-leak sites vs. the average number of organizations named to data-leak sites across all sectors.

Vulnerability Exploitation

This section explores trends in vulnerability exploitation. It details how quickly attackers are exploiting vulnerabilities, which vulnerabilities are most discussed by cybercriminals and researchers, and key incidents from the reporting period.

The most recent quarter saw average time-to-exploitation rise to 13 days across 41 vulnerabilities, up 61% from 8 days across 46 the prior quarter, likely indicating a shift toward more complex, higher-value targets rather than easy opportunities. Rapid exploitation also declined, with same-day exploitation dropping from 21 to 10 CVEs and five-day exploitation from 28 to 20, suggesting fewer flaws were immediately or easily exploitable. Key examples include CVE-2026-20963, a Microsoft SharePoint remote-code execution (RCE) exploited by multiple threat actors, and CVE-2026-21643, a pre-auth SQL injection in Fortinet FortiClient Endpoint Management Server (EMS) that enables unauthenticated code execution, both likely favored for their broad enterprise exposure.

Popular CVEs

CVE	ReliaQuest Intelligence Mentions
CVE-2026-21509 - Microsoft Office RCE vulnerability	16
CVE-2026-20045 - Cisco Unified Communications critical vulnerability	7
CVE-2026-1731 - BeyondTrust Remote Support Critical vulnerability	6
CVE-2026-24858 - Fortinet FortiOS Critical vulnerability	6
CVE-2025-55182 - React Server DOM Critical flaw	6

41

new vulnerabilities exploited

▼ 11%

since last reporting period

Vulnerability Highlights

CVE-2026-33634

CVE-2026-33634 is a CVSS 6.3 embedded malicious code vulnerability in Aqua Security's trivy-action and setup-trivy GitHub Actions. Exploited in the wild since March 19, 2026, the threat actor "TeamPCP" used compromised credentials to inject credential-stealing malware into the tools' version tags, harvesting continuous integration/continuous delivery (CI/CD) pipeline secrets at scale. This incident has since entered a ransomware phase, with the "Vect" ransomware group confirmed as using stolen credentials from this supply-chain compromise to target victims.

Organizations using these tools in their CI/CD pipelines are at direct risk of credential and secrets theft, which can expose cloud environments and downstream systems. A clean version, setup-trivy v0.2.6, is available. Immediately upgrade, rotate all secrets exposed in affected pipelines, and pin GitHub Actions to a specific commit hash rather than mutable version tags per Aqua Security's advisory.

Attacker Target Insights

This section details the initial access attempts that are targeting ReliaQuest’s finance and insurance customers. It also explores how quickly organizations in the sector are responding to threat actor activity. Our agentic AI security operations platform, GreyMatter, allows threats to be detected at the source and in transit. Security teams can contain, investigate, and respond in less than 5 minutes—eliminating Tier 1 and Tier 2 security operations work.

How fast did finance and insurance organizations respond to cyber threats?

The mean time to contain (MTTC) threats increased to 2 hours and 34 minutes during the reporting period, up approximately 49% from 1 hour and 44 minutes since the last reporting period. Multiple factors likely contribute to this increase, and containment timelines are sensitive to the complexity and scope of individual incidents. As such, a single-period increase doesn't necessarily indicate a sustained trend.

↑ 49%

During the reporting period, organizations in the finance and insurance sector using ReliaQuest Automated Response Playbooks achieved an average MTTC of 10 minutes when responding to threats.

Top Techniques

According to our customer incident data, attacks targeting the finance and insurance sector increased by 208% during the reporting period, reflecting a substantial rise in observed technique volume across the sector.

Phishing techniques combined rose to 50% from 29%, driven largely by Phishing for Information emerging as the dominant technique at 39%. External Remote Services and Cloud Accounts also declined meaningfully, though both remain present in the top tier.

Social engineering, particularly information-gathering phishing, is now the defining characteristic of attack activity in this sector.

Top MITRE Techniques Targeting Sector

MITRE ATT&CK Technique	Percentage of All Techniques Observed
Phishing for Information	39
Spearphishing Link	4
Internal Spearphishing	3
Cloud Accounts	3
Spearphishing Attachment	2

Digital Risk Protection

This section explores the biggest GreyMatter Digital Risk Protection (DRP) risks to the finance and insurance sector. If a risk is detected, customers receive context-rich alerts via the GreyMatter alert process, with clear response steps including assignment and mitigation recommendations.

Impersonating domains became the dominant alert type this period, displacing credential exposures, which fell sharply from first place. Threat actor mentions also accounted for a larger share of alerts overall. This change could suggest that adversaries targeting the finance and insurance sector prioritized brand-spoofing infrastructure to harvest credentials this period, rather than relying on previously leaked ones.

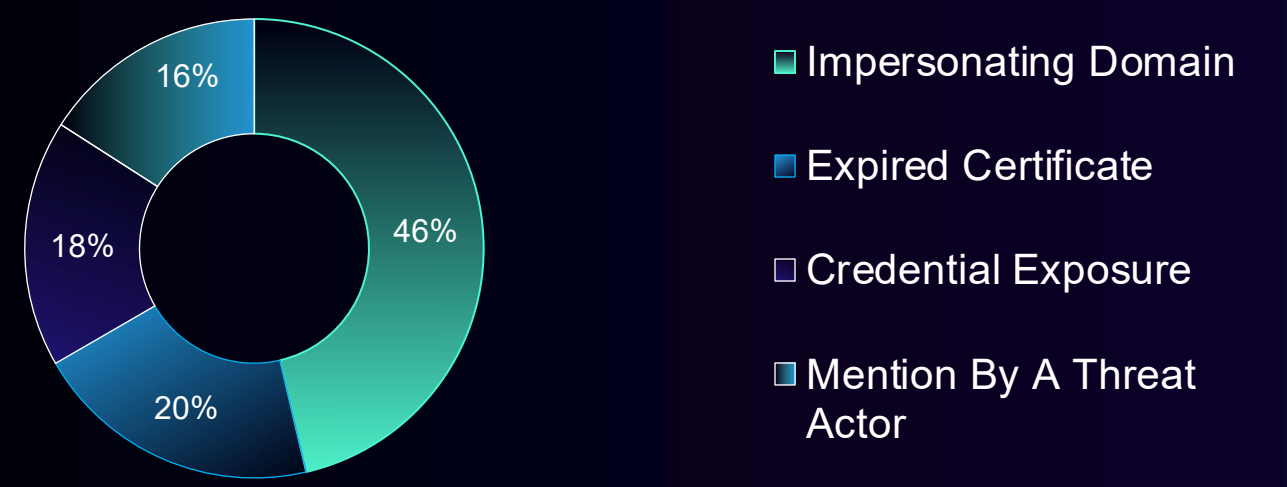


Figure 2: DRP alerts by type for finance and insurance customers this reporting period

All-Sector Top DRP Alerts (for comparison)

Risk Type	Percentage
Credential Exposure	30
Impersonating Domain	24
Impersonating Subdomain	18
Selling Unauthorized Goods	7
Expired Certificate	6

Countries Targeted

Publicly known cyber events targeting organizations in the finance and insurance sector increased substantially, with overall alert volume rising by 52% period over period. The United States remained the dominant target, accounting for 41% of activity. Israel's emergence as the second-most targeted country, now representing 6% of events, is consistent with the joint US-Israel strikes on Iran in February 2026 and the retaliatory cyber campaign that followed, with Iran-aligned actors known to target Western and Israel-linked financial infrastructure during periods of kinetic escalation. The United Arab Emirates also saw a notable rise, now at 4%, likely reflecting broader Middle East spillover from the same conflict.

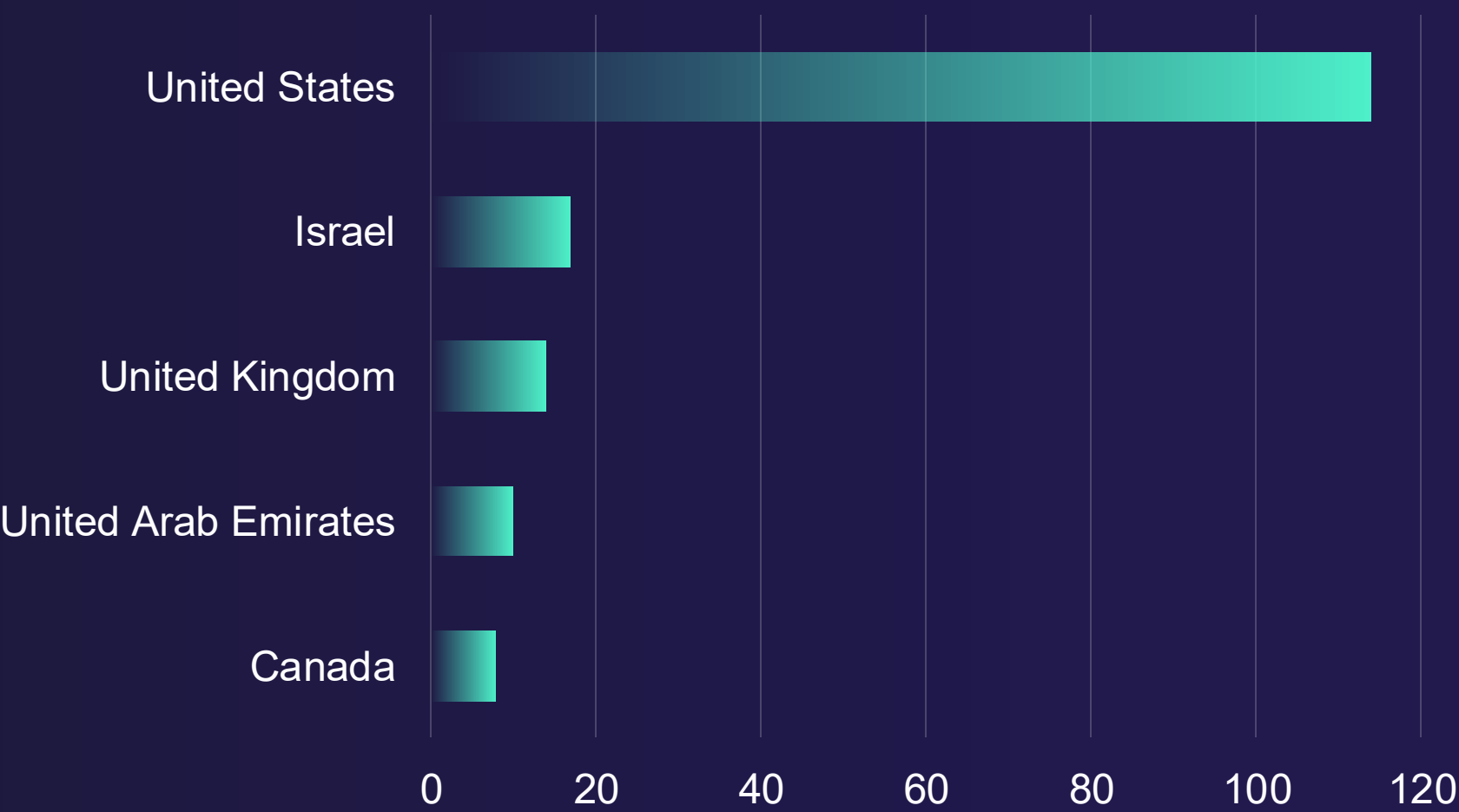


Figure 3: Number of significant cyber events, by region

Notable Developments

Verifone Targeted by Pro-Iranian Hacktivists

Pro-Iran hacktivist group "Handala" allegedly attacked Verifone, a global payment solutions provider, on March 11, 2026, claiming to have disrupted payment systems and extracted financial transaction data. These claims are unverified. For the finance and insurance sector, this raises fraud risk and potential exposure of sensitive merchant and customer financial data.

[Read More](#)

■ March 11, 2026

Chinese APT Hijacks Notepad++ Update Infrastructure

"Lotus Blossom," a Chinese advanced persistent threat (APT) group, hijacked the Notepad++ supply-chain update infrastructure via a hosting provider compromise active between June and December 2025. Financial services is among the high-value sectors likely targeted through selective update traffic redirection, posing a realistic possibility of targeted intrusions against finance and insurance organizations.

[Read More](#)

■ February 2, 2026

APT42 Targets High-Value Executives via Spearphishing

Iranian state-sponsored group "APT42" conducted a spearphishing campaign targeting a high-profile executive, using spoofed emails, malicious .lnk files, and command-and-control (C2) communications via Dropbox to evade detection. For the finance and insurance sector, where executives hold strategic influence, this threat is likely to intensify through Q1 and Q2 2026 as geopolitical tensions persist.

[Read More](#)

■ January 23, 2026

Notable Developments

North Korean Actor Targets Finance with AI

ReliaQuest identified North Korean group "UNC1069" targeting cryptocurrency and finance sector organizations via AI-generated Deepfake Zoom calls and Telegram. Victims are tricked into running "ClickFix" commands that deploy a modular malware toolkit, stealing credentials, browser session data, and authentication tokens to enable unauthorized access to financial accounts and cryptocurrency wallets.

[Read More](#)

■ February 10, 2026

North Korean Hackers Target Finance Developers

North Korean state-sponsored actors, "Lazarus Group" and "APT38," are impersonating recruiters to trick software developers in the finance and insurance sector into installing a malicious dictionary app. The trojan deploys the "BeaverTail" downloader and "InvisibleFerret" backdoor, harvesting browser credentials, session cookies, and cryptocurrency wallet data, directly threatening financial institutions.

[Read More](#)

■ January 20, 2026